

Aegis-Agency: Byzantine-Robust, Injection-Hardened Multi-Agent Defense Pipelines

Secure Multi-Agent Systems — Research Idea Repository

Research concept note for collaborator discussion (not a paper)

Target Venues

Primary [ACM CCS](#); also [USENIX Security](#), [IEEE S&P](#), [NDSS](#), and the journal [IEEE TDSC](#). Fit: a redesigned *defensive* multi-agent architecture that tolerates compromised insiders and adaptive attackers matches the applied-security scope of the conferences and the dependability/fault-tolerance scope of TDSC.

Motivation

Multi-agent defense pipelines now filter LLM outputs. AutoDefense (arXiv:2403.04783) chains an Input agent, an Intention Analyzer, an Original-Prompt Analyzer, and a Judge under a Coordinator (optional Llama-Guard fourth agent, then an Output agent), and reduces jailbreak attack success rate — reported, e.g., from 55.7% to 7.95% with a LLaMA-2-13b three-agent configuration. But the *defense is itself a multi-agent system* whose own security is unexamined: it assumes every internal defender is honest; its Coordinator is a single trust/aggregation point with no voting, quorum, or Byzantine tolerance; it feeds the *untrusted* response straight to its judges (a second-order prompt-injection surface *against the defenders*); it is tested only against static attacks; and it targets *jailbreak* (harmful content), not prompt *injection* (task-integrity violations that can look benign). A single hardened model (SecAlign, arXiv:2410.05451) has no colluding co-defender and no compromised coordinator — those threats appear only when the defense is a team.

Research Gap

- **AutoDefense (arXiv:2403.04783)** — multi-agent response filter; assumes honest agents, a single Coordinator with no Byzantine tolerance, feeds untrusted content to judges, is tested only statically, and defends jailbreak, not injection/task-integrity.
- **Krum (Blanchard et al., NeurIPS 2017)** — Byzantine-robust selection with tolerance condition $2f + 2 < n$, but for gradient aggregation under a *trusted* master.
- **SecAlign (arXiv:2410.05451) and StruQ (arXiv:2402.06363)** — injection-hardened *single* models (preference optimization; structured-input/delimiter separation); no team-level insider or aggregation threat.

No corpus defense tolerates compromised or colluding *internal* defenders, resists second-order injection from the content it inspects, or is stress-tested by an attacker adapting against the pipeline.

System and Threat Model

System. A defense “agency”: an Input agent, one or more Analyzer agents, a set of Judge agents (1–7), and an Output agent. The single Coordinator is replaced by a Byzantine-robust aggregation rule over judge verdicts; the inspected payload (a candidate response and/or an inter-agent message) is untrusted. **Attacker objective:** make the agency pass an unsafe/injected output (integrity) or over-refuse benign outputs (availability). **Knowledge:** black-box to gray-box; may know the pipeline design; adaptive. **Capabilities:** (i) compromise/collude with one or more internal defenders; (ii) simultaneously inject the inspected content to attack the judges reading it (second-order injection); (iii) adapt to the aggregation rule. **Collusion:** colluding defenders coordinate verdicts to flip aggregation. **Trusted:** the aggregation substrate executes correctly; at least $n - f$ judges are honest (with $2f + 2 < n$ for a Krum-style rule); the inspected payload is confined to a data channel. **Out of scope:** all judges compromised; an identical correlated failure across judges (studied as a limiting case, not assumed defended).

Core Idea

A **defense architecture** that tolerates compromised/colluding internal defenders and resists second-order injection from the content it inspects. Four components: (1) *Byzantine-robust verdict aggregation* over defenders — a Krum/coordinate-median rule replacing the single Coordinator, so a malicious minority cannot flip the decision; (2) *strict isolation* of the untrusted inspected payload from defender instructions (StruQ-style delimiting / structured input) so the judges cannot themselves be injected by what they read; (3) *hardened judge agents* fine-tuned with SecAlign/StruQ so each individually resists injection; (4) *generalization from jailbreak to injection/task-integrity*, extending the verdict target from “harmful content” to “violated the intended task/instruction hierarchy.” The claim is graceful degradation under insider compromise and second-order injection — explicitly *not* that reduced ASR equals “secure.”

Novelty

Vs. closest work. AutoDefense (arXiv:2403.04783) assumes honest agents, a single coordinator, and only static attacks; Krum (NeurIPS 2017) is robust only under a trusted master; SecAlign (arXiv:2410.05451) and StruQ (arXiv:2402.06363) harden a lone model. **Not a model-swap / prompt-filter / engineering tweak:** swapping in a hardened judge (component 3 alone) is exactly our single-model baseline; the contribution is (a) removing the trusted-coordinator assumption via Byzantine-robust aggregation over defenders and (b) closing the second-order injection surface the defense creates by reading untrusted text — neither expressible for one model. **Fundamentally multi-agent:** the object being defended is a *team* with insider risk and an internal aggregation point. Colluding-defender and coordinator-compromise threats have no single-agent analog; a lone SecAlign model has no co-defender to collude and no aggregator to subvert, and composing per-agent hardened models without robust aggregation addresses neither.

Expected Contributions

- A threat model for *insider* compromise and *second-order* injection inside a defense pipeline — the first to drop AutoDefense’s honest-agent and single-coordinator assumptions.

- **Aegis-Agency**, an architecture combining Byzantine-robust verdict aggregation, payload isolation, and hardened judges, generalized from jailbreak to injection/task-integrity.
- An adaptive-attack evaluation against the pipeline (compromised judge, colluding defenders, second-order payload injection, attacks on the aggregation rule) — absent from prior multi-agent defenses.
- A security-vs-cost frontier: Byzantine tolerance fraction vs. latency and token/API cost as the number of hardened defenders grows.
- A stated diversity requirement and analysis of correlated failure when judges share a base model (*hypothesis*).

Preliminary Technical Direction

Flow. The inspected payload enters a *data* channel isolated (StruQ-style delimiters / structured fields) from each judge’s *instruction* channel. Each of n hardened judges emits a verdict v_k (allow/block plus a calibrated score and rationale embedding). **Robust aggregation.** A Krum/geometric-median selection over $\{v_k\}$ in verdict/embedding space replaces the Coordinator; under the Krum condition $2f + 2 < n$, up to f Byzantine judges cannot force an adversarial verdict — a target property to establish for the semantic verdict space, *to be proven*, not assumed. **Generalization.** Redefine the verdict target from harmful-content classification to task-integrity: did the candidate violate the original instruction/privilege hierarchy? **Diversity.** Krum tolerance is vacuous if all judges fail identically, so we require backbone/prompt diversity and measure residual correlation. **Non-claim:** lower ASR-under-compromise is evidence of robustness, not a proof of security; residual failures are reported.

Evaluation Strategy

LLM families. Judges and analyzers on open (Llama-3, Qwen2.5, Mistral) and proprietary (GPT-4o, Claude-3.5) backbones, homogeneous and diverse. **Number of defenders.** 1–7 judges. **Adversary.** malicious/colluding fraction swept from independent single-compromise to colluding minorities up to the $2f + 2 < n$ boundary; static vs. adaptive attacks on the pipeline and the aggregation rule. **Attacks.** compromised-judge; colluding-defenders; second-order injection of the inspected payload; adaptive attack on aggregation. **Baselines.** AutoDefense (single Coordinator); a single hardened model (SecAlign); plain majority vote. **Metrics.** defense success rate; ASR-under-compromise and targeted-ASR; false-positive/over-refusal rate; Byzantine tolerance fraction; detection F1/AUROC of malicious verdicts; latency (linear in the number of agents — quantified); token/API cost; utility retention on benign traffic. **Ablations.** robust-aggregation on/off; payload isolation on/off; hardened judges on/off; number of defenders 1–7; colluding fraction; homogeneous vs. diverse backbones (correlated-failure test).

Potential Risks

- **Cost/latency.** Many hardened judges plus aggregation raise latency and token/API cost; the security-vs-cost frontier may be unattractive at small n .
- **Small-committee tolerance.** With 3–5 judges the Krum condition $2f + 2 < n$ tolerates very few faults ($f = 1$ needs $n \geq 4$); whether this is meaningful robustness is an open empirical question, not assumed.

- **Correlated failure.** If all judges share a base model they may fail identically, voiding Byzantine tolerance; the required diversity may be hard to achieve (*hypothesis*).
- **Utility / interpretation.** Robust aggregation biased toward blocking could raise false positives (over-refusal is measured explicitly); reduced ASR-under-compromise is not “secure,” and residual failures are reported.

Publication Readiness

Strong fit for CCS/USENIX/S&P/NDSS (adaptive, insider-aware defense) and TDSC (fault-tolerance study). **Confidence: 7/10.** The gap is concrete and cited (AutoDefense’s honest-agent/single-coordinator assumptions; Krum’s trusted-master premise; SecAlign/StruQ single-model) with clear multi-agent necessity. Held below Contagion by two feasibility risks — meaningful tolerance from a small judge committee, and defeating correlated failure via backbone diversity — both directly tested by the ablations.